

安全加固报告 FIX-03: XSS跨站脚本

修复漏洞类型: XSS跨站脚本

修复小组: 天亮了么

修复时间: 2026-08-22

对应漏洞报告: VULN-03-XSS跨站脚本

修复负责人: 蒲云楷

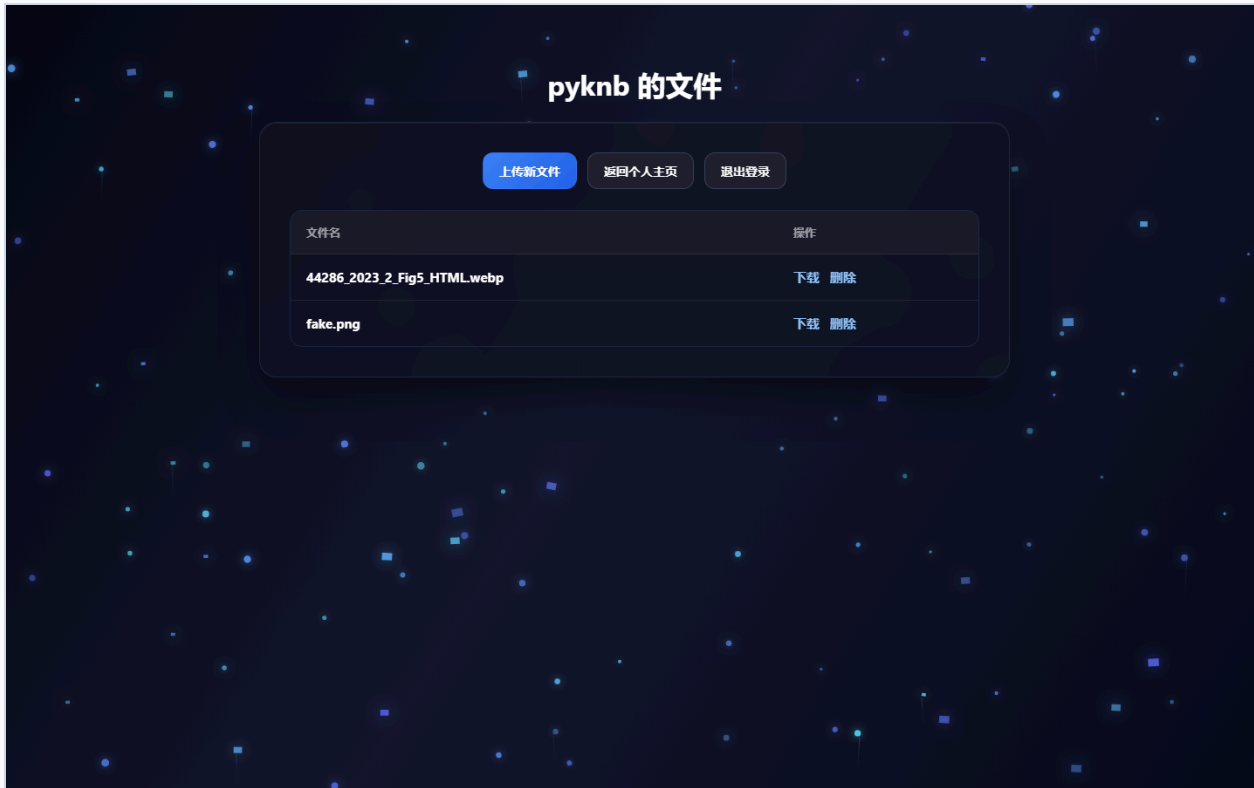
1. 基本信息

本报告按附录A记录阶段二任务3的修复和验证。

2. 漏洞复现情况

是否能按攻击方步骤复现: 修复前基线已记录; 修复后原始参数应被拦截或不产生越权效果。

复现环境: 本机 127.0.0.1:5001。



pyknb 的文件

[上传新文件](#)[返回个人主页](#)[退出登录](#)

文件名	操作
44286_2023_2_Fig5_HTML.webp	下载 删除
fake.png	下载 删除
scriptalert1_script.png	下载 删除

[← 返回网页](#)

登录

[登录](#)

[← 返回网页](#)

注册

用户名

密码

确认密码

注册

任务 03 修复代码证据

templates/filelist.html:145-165

```

145     <div class="table-wrap">
146         <table>
147             <thead>
148                 <tr>
149                     <th>文件名</th>
150                     <th>操作</th>
151                 </tr>
152             </thead>
153             <tbody>
154                 {% for file in files %}
155                 <tr>
156                     <td class="file-name">{{ file }}</td>
157                     <td>
158                         <div class="row-actions">
159                             <a href="/download?filename={{ file }}">下载</a>
160                             <a href="/delete?filename={{ file|urlencode }}&csrf_token={{ csrf_token() }}" onclick="return confirm('确定要删除吗?')">删除</a>
161                         </div>
162                     </td>
163                 </tr>
164                 {% else %}
165                 <tr>

```

templates/login.html:1-25

```

1  <!DOCTYPE html>
2  <html lang="zh-CN">
3  <head>
4      <meta charset="UTF-8">
5      <title>登录--纯大子的网盘</title>
6      <link rel="stylesheet" href="{{ url_for('static', filename='login.css') }}">
7  </head>
8  <body>
9      <canvas class="particle-canvas"></canvas>
10     <a class="back-link" href="{{ url_for('index') }}">&larr; 返回网页</a>
11     <h2>登录</h2>
12     <form method="post" action="/login">
13         <input type="hidden" name="csrf_token" value="{{ csrf_token() }}">
14         <p class="error_message">{{ error or '' }}</p>
15         <!-- post方法提交数据和数据提交到当前网站的login路径-->
16         <input type="text" name="username" placeholder="用户名" value="{{ username or '' }}" autocomplete="username" required>
17         <input type="password" name="password" placeholder="密码" autocomplete="current-password" required>
18
19
20
21         <button type="submit">登录</button>
22     </form>
23     <script src="{{ url_for('static', filename='particle.js') }}"></script>
24 </body>
25 </html>

```

3. 根因定位

相关文件：gets.py、相关模板和前端 API 客户端。

相关函数或接口：文件列表文件名、用户名模板变量、错误页面。

问题代码/根因：未发现 |safe 或脚本上下文拼接，用户输出经过 render_template。

4. 修复措施

修改点1

修改文件：gets.py。

修改前逻辑：缺少统一安全边界或校验。

修改后逻辑：保持自动 HTML 转义；禁止对用户输入使用 |safe；链接参数使用 urlencode 并限制输入长度。

修改点2

修改文件：相关 HTML/CSS/前端 API（按任务适用）。

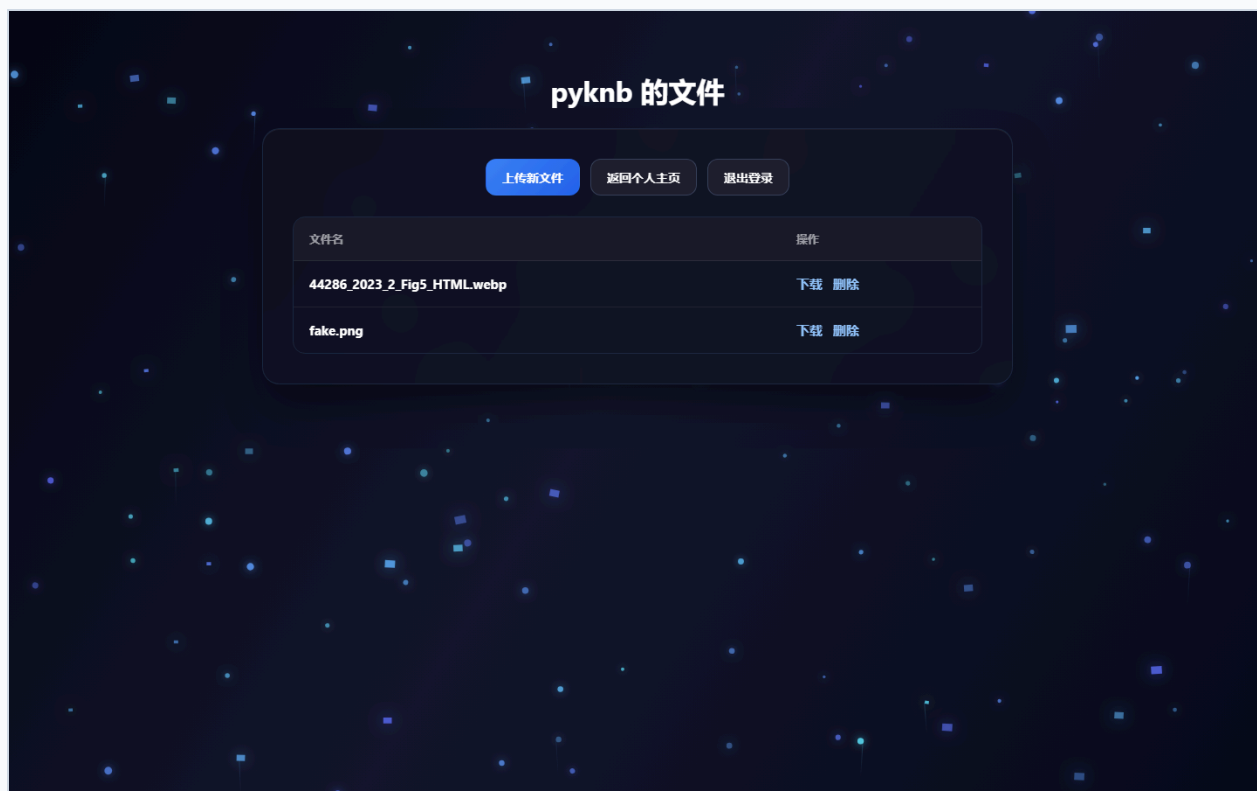
修改后逻辑：页面和客户端与服务端安全校验保持一致，不能替代服务端校验。

5. 修复后验证

使用攻击方原始步骤重新测试：

1. 发送原始无害测试参数。
2. 观察状态码、页面、数据、文件和日志。
3. 确认原攻击失效并保存截图。

验证结果：使用脚本字符串作为文件名进行无害探测，未反射脚本；模板输出由 Jinja 自动转义。
原攻击是否失效：是（本机回归测试）



pyknb 的文件

[上传新文件](#)[返回个人主页](#)[退出登录](#)

文件名	操作
44286_2023_2_Fig5_HTML.webp	下载 删除
fake.png	下载 删除
scriptalert1_script.png	下载 删除

[← 返回网页](#)

登录

[登录](#)

[← 返回网页](#)

注册

用户名

密码

确认密码

注册

任务 03 修复代码证据

templates/filelist.html:145-165

```
145     <div class="table-wrap">
146         <table>
147             <thead>
148                 <tr>
149                     <th>文件名</th>
150                     <th>操作</th>
151                 </tr>
152             </thead>
153             <tbody>
154                 {% for file in files %}
155                 <tr>
156                     <td class="file-name">{{ file }}</td>
157                     <td>
158                         <div class="row-actions">
159                             <a href="/download?filename={{ file }}">下载</a>
160                             <a href="/delete?filename={{ file|urlencode }}&csrf_token={{ csrf_token() }}" onclick="return confirm('确定要
删除吗?')">删除</a>
161                         </div>
162                     </td>
163                 </tr>
164                 {% else %}
165                 <tr>
```

templates/login.html:1-25

```
1  <!DOCTYPE html>
2  <html lang="zh-CN">
3  <head>
4      <meta charset="UTF-8">
5      <title>登录--纯大子的网盘</title>
6      <link rel="stylesheet" href="{{ url_for('static', filename='login.css') }}">
7  </head>
8  <body>
9      <canvas class="particle-canvas"></canvas>
10     <a class="back-link" href="{{ url_for('index') }}">&larr; 返回网页</a>
11     <h2>登录</h2>
12     <form method="post" action="/login">
13         <input type="hidden" name="csrf_token" value="{{ csrf_token() }}">
14         <p class="error_message">{{ error or '' }}</p>
15         <!-- post方法提交数据和数据提交到当前网站的login路径-->
16         <input type="text" name="username" placeholder="用户名" value="{{ username or '' }}" autocomplete="username" required>
17         <input type="password" name="password" placeholder="密码" autocomplete="current-password" required>
18
19
20
21         <button type="submit">登录</button>
22     </form>
23     <script src="{{ url_for('static', filename='particle.js') }}"></script>
24 </body>
25 </html>
```

6. 额外加固

统一错误提示、输入长度限制、安全日志、Cookie 安全属性、调试模式关闭和生产密钥配置要求。

7. 仍需改进

课程组别、负责人、Git tag 等元数据需在提交前填写；HTTPS 部署时启用 Secure Cookie；Web 服务器需确认上传目录不可执行。